



15.1 Student Guide: Introduction to Pen Testing and OSINT

Overview

Today's class will introduce penetration testing, or pen testing, and its value to organizational security. We'll discuss career pathways and explore the first phase of pen testing using open-source intelligence (OSINT) tools.

Class Objectives

By the end of class, you will be able to:

- Understand the role of a pen tester in assessing a business's security.
- Collect domain information by using OSINT techniques and tools like Google hacking, Shodan, and certificate transparency.
- Use Shodan and Recon-ng to discover domain server information.

Slideshow

The lesson slides are available on Google Drive here: [15.1 Slides](#).

Lab Environment

For this module, you will use the penetration testing Cloud Labs environment.

The credentials for the Kali VM are un:root, pw:kali

Because this environment uses nested Hyper-V machines, refer to the [Hyper-V guide](#) for additional information.

01. Introduction to Penetration Testing

We've covered various cyber attacks and vulnerabilities so far. Now, we will look at a specific professional role that partners with organizations to assess their security postures, vulnerabilities, and susceptibility to attacks, called **penetration testing**.

This lesson will cover the following:

- An introduction to penetration testing and its business goals
- A high-level overview of the various stages of a pen-test engagement
- A deep dive into the first step of a penetration test: **Planning and reconnaissance**

The techniques we will learn in this module can be used to break into networks and do serious damage to an organization's infrastructure.

This is illegal when done without permission. You should understand that the tools and techniques discussed today are serious, and misusing them can have serious consequences. Never practice these techniques against computers that you do not own or do not have clear written permission to interact with.

What Is Penetration Testing?

While network administrators and security personnel do their best to harden their networks, it often takes an external entity to identify misconfigurations and subtle security holes.

- Penetration testing, often referred to as **pen testing** or **ethical hacking**, is the offensive security practice of attacking a network using the same techniques that a malicious hacker would use in an effort to identify security holes and raise awareness within an organization.
 - Organizations hire pen testers to assess their security controls. Pen testers find flaws in those controls, help the organization understand these flaws, and recommend which vulnerabilities to prioritize and how to fix them.
 - Pen tests are often administered by consultancies, which can take an "outside" view of a client's networks.
 - In the simplest terms, pen testers aim to break into a client's machine, infrastructure, or even physical premises to help the client improve their security.
 - A pen test is often referred to as an **engagement** by practitioners.
 - Pen testers, unlike malicious hackers, do this only after receiving permission from the security owner to begin an engagement.
 - Pen testers use a combination of automated tools and manual tools to research vulnerabilities, craft phishing emails, manually exploit hosts, and write shell code. They use these tools creatively, just as malicious hackers do.

Module Overview and Penetration Testing Phases

In this week's activities, you will play the role of a consultant at **GoodCorp**, hired to conduct a pen test against **MegaCorpOne**.

- MegaCorpOne specializes in disruptive innovation in the nanotechnology industry and has hired GoodCorp to run a penetration test.
- You will be tasked with going through the pen testing engagement to assess MegaCorpOne's security.
- You will conclude your test with a report, so be sure to keep all of your findings as you proceed through the penetration testing activities.

During an engagement, pen testers follow a methodology designed to mimic an actual attack. This helps network defenders understand the effectiveness of their organization's defenses.

An engagement consists of the following five phases:

1. **Planning and reconnaissance:** This first phase consists of two parts:
 - **Planning:** During this pre-engagement step, the purpose and scope of the test are defined and all legal contracts are signed.
 - **Reconnaissance:** This step consists of obtaining publicly available information about your target.
2. **Scanning:** This phase consists of using tools to run a **scan** against your target to gather information, such as open ports and running services to determine potential vulnerabilities.
3. **Exploitation:** This phase consists of attacking the vulnerabilities discovered in the previous steps to gain access to the target.
4. **Post-exploitation:** This phase consists of gathering valuable information from the compromised systems.
5. **Reporting:** This final phase consists of reporting on the previous five steps, providing a summary of actions taken, findings, and recommended mitigations.

During the four classes in this module, we will proceed through these five phases as we conduct a penetration test against **MegaCorpOne**.

- Day 1: Planning and reconnaissance phase
- Day 2: Scanning phase
- Day 3: Exploitation and post-exploitation phases
- Day 4: Reporting phase

Keep your findings from each activity in this module, because you will use them on the fourth day to create your pen test report.

While we've discussed these phases sequentially, as in a real attack, there are times when steps are skipped or repeated and when their order is switched. For example:

- In a real attack, an attacker may be able to skip reconnaissance and scanning and directly attempt an exploit, then return to reconnaissance later to gather additional information once inside the target.
 - In some types of pen tests, the client may provide the pen tester with network diagrams and system access. In that case, the pen tester could skip the recon, scanning, and exploitation phases as they already have access to their target.
 - Pen testers may also vary the sequence of these phases from one engagement to the next, depending on the client and situation. In this module, you will experience some exceptions to the typical sequence of phases.
-

02. Planning the Penetration Test

Before a penetration test starts, it must be planned. This is part of the planning and reconnaissance phase.

- This step is an interaction between the organization and the pen testing team.
- It helps the pen tester understand the client's needs before beginning the test.

Most businesses' primary interest is not how attackers might gain access to their networks.

- Instead, they are concerned with how an exploited vulnerability may affect their reputation, operations, or bottom line.

The first form of contact during planning is usually a kick-off call or meeting, during which clients work with pen testers to determine the purpose and scope of the project:

- **Purpose** is defined by clarifying the business's needs and concerns and communicating which assets it is most interested in protecting.
- **Scope** is defined by informing pen testers which machines and networks are off limits and should not be targeted for attack.
 - Some production systems may be off limits due to a fear of downtime if the system becomes compromised. Unlike actual malicious hackers, pen testers often have rules they have to follow.
 - Penetration tests also typically have a defined time limit, commonly between a few days and a few weeks. The client may even specify particular times of day.
 - Often, only a few executives or security personnel at the client organization know about an ongoing engagement.
 - Because of this, pen testers often carry a "get out of jail" card or a document with them to prove that they were hired by a staff member in case they are identified as an attacker.

The pen testing team will scope their test accordingly, seeking to:

- Demonstrate potential business impact due to vulnerabilities in the network.

- Provide recommendations for mitigating those vulnerabilities in the future.

The primary deliverable from this stage is a document summarizing the engagement's purpose and scope and associated details such as time frame and emergency contacts.

The scope will also specify the type of penetration test that will be run.

Types of Penetration Testing

There are three primary types of penetration tests: **No view**, **full view**, and **partial view**.

- In **no-view** testing, also known as **black-box** testing, the pen tester simulates a malicious hacker who has no prior knowledge of the target system and network. The tester is paid to learn and exploit as much as possible about the network using only the tools publicly available on the internet.
 - For example, they may only know the company name and have to find various key resources, like IP ranges and access credentials.
- In **full-view** testing, also known as **white-box** testing, the pen tester is given full knowledge of the system or network. This knowledge allows them to tear apart subtle security issues on behalf of their clients. Full-view pen testing is most appropriate when the client wants a detailed analysis of all potential security flaws, rather than exposed and visible vulnerabilities.
 - Full-view testers are given network diagrams, access credentials to the networks, system names, usernames, emails, and phone numbers.
- **Partial-view** testing, also known as **gray-box** testing, involves providing testers with partial knowledge of the target. These engagements are often performed by the in-house system or network administrator.

While every pen test can be categorized as either full view, no view, or partial view, there are other subtle differences between engagements. An example is the extent to which the organization's employees know about the engagement and how much the pen tester knows about the company.

Regardless of the scenario, the main deliverable for any pen tester is a report that summarizes their findings and recommendations for improvements.

Statements of Work and Legal Indemnification

There are several legal steps required before beginning a security assessment.

- Since penetration testing is hacking, there must be consent from the entity being hacked.
- To protect the assessors from legal ramifications, both parties must agree on and sign a **statement of work (SoW)**.
 - A SoW outlines the scope of the test, the timeline, the points of contact, and how the test will be conducted.

 **Important Reminder:** Penetration testing without a contractual agreement is *illegal* unless it is conducted on your own network or devices.

Verbal consent is very hard, nearly impossible, to prove in court. If someone asks you to pen test their network without a SoW and then sues you, they can prove that you attacked their network but you cannot prove that they verbally agreed to it.

Review the following examples of legal and illegal penetration testing assessments:

- **Legal:** A financial institution asks you to perform a penetration test on their private network. They will provide access to all the necessary credentials and architecture diagrams. You will also meet with them beforehand to sign a contract clearly illustrating the scope and purpose of the test.
 - This is a legal full-view penetration test because you signed a contract before you began your assessment.
- **Illegal:** A friend asks you to perform a penetration test on a social media website that they just joined, as they want to make sure their information is safe.
 - This is an illegal no-view test, because neither the friend nor you own the social media website network or devices, and the social media website has not granted permission or signed a contract authorizing this test.

Summary

- **Penetration testing**, often referred to as **pen testing** or **ethical hacking**, is the offensive security practice of attacking a network using the same techniques that a malicious hacker would use in an effort to identify security holes and raise awareness within an organization.
- The five phases of a pen testing engagement are **planning and reconnaissance**, **scanning**, **exploitation**, **post-exploitation**, and **reporting**.
- During the planning phase, the engagement's scope and purpose are defined.
 - The **purpose** is defined by clarifying which assets the business is most interested in protecting.
 - The **scope** is defined by clarifying which machines and networks are off-limits during the "attack."
 - The scope also includes the type of penetration test that will be run. Types include **no view**, **full view**, and **partial view**.
- A **SoW (statement of work)** is also completed during the planning phase. It outlines the scope of the test, the timeline, the points of contact, and how the test will be conducted.

In the first activity, we will roleplay as a penetration tester who has been given several contracts and must determine what type of pen test each involves and whether it's legal.

03. Activity: Types of Penetration Testing

- [Activity File: Types of Penetration Testing](#)
-

04. Activity Review: Types of Penetration Testing

05. Intro to MITRE ATT&CK

Penetration testing is a methodical process. The type of assessment will determine where the pen tester begins.

A company called **MITRE** developed the **MITRE ATT&CK matrix** to provide a visual representation of all the different **techniques, tactics, and procedures (TTPs)** that may be performed throughout an assessment.

- We will use this matrix as a reference for the TTPs we will conduct throughout the next two weeks of class.
- Not every tactic or technique in the matrix will be used in any single engagement.

Refer to the following website: <https://attack.mitre.org/matrices/enterprise/>.

- Each **header** represents a tactic. For example, the first tactic listed is **reconnaissance**. It's listed first because attackers conduct reconnaissance on a target before performing any exploitation.
- Each **row** under the header is a technique. For each tactic, there are multiple techniques. For example, during reconnaissance, an attacker may use **active scanning** to gather information or **search open technical databases** to gather similar information.
 - The appropriate techniques to use depend on what you're trying to accomplish. Active scanning, for example, is great for gathering a list of open ports but not for gathering credentials. Phishing would be the opposite.

MITRE ATT&CK isn't so much a ruleset as it is a "hacker's playbook." The matrix is comprehensive, meaning that virtually every potential attack falls under a tactic and maps to a specific technique. As a penetration tester, it's beneficial to map out the techniques you performed so the customer can learn what TTPs were successful and what needs to be addressed.

- This week's module will follow the MITRE ATT&CK matrix tactics from left to right. We won't teach every tactic, but we'll begin by learning about reconnaissance today.

MITRE is a powerful matrix. You should follow and reference it for several reasons:

- It is comprehensive and includes almost every possible tactic or technique that an attacker could perform during a hack.
- During the reporting process, it's important to reference specific tactics and techniques that an attacker would use. This matrix helps abstract technical topics for less technical staff.
- It helps create a more comprehensive report by categorizing specific security deficiencies. For example, if a red team successfully demonstrates several techniques under the **lateral movement** tactic, it highlights that tactic as a security hole in the organization.

We will incorporate MITRE into our reporting activities on Day 4.

06. Reconnaissance with OSINT and Google Hacking

In this section, we will cover the next part of a penetration test, reconnaissance, which is also part of the planning and reconnaissance phase.

- Reconnaissance is also the first MITRE ATT&CK tactic.

Reconnaissance, or **recon**, is the act of gathering information about your target.

- Reconnaissance is divided into two types: Passive and active.
 - **Passive recon** often refers to **open-source intelligence (OSINT)**, which leverages publicly available information about the target. This includes all domains and hosts belonging to a target that are publicly viewable.
 - **Active recon** also refers to gathering information about the target, but it involves directly interacting with the target.
- Reconnaissance can be conducted externally (**external reconnaissance**) from the target or internally (**internal reconnaissance**) after accessing the target.

The first passive reconnaissance tactic we will explore leverages Google, which is known as Google hacking or Google dorking.

Google Hacking

Sometimes we're able to identify useful information on the public internet using search engines.

Google hacking enables us to manipulate Google searches to narrow down our queries to acquire actionable intel.

- For example, with a Google search, we could identify email addresses associated with our target. The email addresses could then be used for future phishing campaigns or even a brute-force attack where we guess a password with the email address on a login

page.

- Sometimes, companies accidentally leave sensitive information on the public internet, allowing it to be found through a search engine.
 - For example: [Vice News: ISP Left Corporate Passwords and Keys Exposed](#).

Google hacking falls under the technique **Search Open Websites/Domains: Search Engines, ID T1593-002**: <https://attack.mitre.org/techniques/T1593/002/>.

Next, we will demonstrate some simple Google hacking techniques.

Google Hacking Demonstration

In this demonstration, we will show the basic functionality of Google hacking. You will then apply this tool to gather OSINT in the next activity.

1. In a browser, navigate to www.google.com.
2. In the search bar, enter "site:sans.org".
 - This search will filter results to only show links belonging to sans.org.
3. Next, in the search bar, add to the existing search "type:pdf", so the search is now "site:sans.org type:pdf."
 - This search will filter all results to show only PDF documents from the sans.org website.
4. Replace "type:pdf" with "intext:password", so the search is now "site:sans.org intext:password."
 - This will show any webpage with "password" on the page. This is especially useful for searching for passwords.

Refer to the following additional resources:

- [Cybrary: Google Hacking Commands](#)
- [SANS.org: Google Cheat Sheet](#)

Summary

- **Reconnaissance**, which is part of the **planning and reconnaissance** phase, means gathering information about your target.
- **Passive recon** often refers to **open source intelligence (OSINT)**, which leverages information about the target that is publicly available on the internet. This includes all domains and hosts belonging to a target that are publicly viewable.
- **Active recon** refers to directly interacting with the target to obtain information.

- Reconnaissance can be conducted externally (**external reconnaissance**) from the target or internally (**internal reconnaissance**) after accessing the target.
- **Google hacking** is a reconnaissance technique that enables us to manipulate Google searches to narrow down our queries to acquire actionable intel.

In the next activity, we will continue to play the role of a penetration tester and conduct a reconnaissance tactic by using Google hacking to find information about a fictional organization.

07. Activity: Google Hacking

- [Activity File: Google Hacking](#)

08. Activity Review: Google Hacking

09. Break

10. Certificate Transparency

We will continue our reconnaissance by exploring **certificate transparency**.

- Certificate issuers publish logs of the SSL/TLS certificates that they issue to organizations. This is known as **certificate transparency**.
- An SSL/TLS certificate is used to make an HTTP site HTTPS—that is, **secure**.
- This certificate transparency can be exploited by attackers and used to search for subdomains.
- Using certificate transparency to find subdomains of targets falls under the **Search Open Technical Databases: Digital Certificates** MITRE technique, ID **T1596.003**.
 - <https://attack.mitre.org/techniques/T1596/003/>.

Remember: Every technique we are performing is attributable back to MITRE. This reference can not only help provide ideas about what to do next as a penetration tester, it can also help defenders recognize what attacks are possible.

Certificate Transparency Demonstration

Let's briefly demonstrate the process of finding subdomains using certificate transparency:

1. Open a web browser and navigate to the certificate searching tool at <https://crt.sh>.

- Enter "sans.org" into the search box.
- Contained within our search results are all the certificates associated with every variation of the example.com domain, as the following image shows:

crt.sh ID	Logged At	Not Before	Not After	Common Name	Matching Identities	Issuer Name
4824391605	2021-07-07	2021-07-07	2021-10-05	text.sans.org	text.sans.org	C=US, O=Let's Encrypt, CN=R3
4824390849	2021-07-07	2021-07-07	2021-10-05	text.sans.org	text.sans.org	C=US, O=Let's Encrypt, CN=R3
4812211618	2021-07-05	2021-07-05	2021-10-03	ics-community.sans.org	ics-community.sans.org	C=US, O=Let's Encrypt, CN=R3
4812211645	2021-07-05	2021-07-05	2021-10-03	ics-community.sans.org	ics-community.sans.org	C=US, O=Let's Encrypt, CN=R3
4806436506	2021-07-04	2021-07-04	2021-10-02	ssahub.sans.org	ssahub.sans.org	C=US, O=Let's Encrypt, CN=R3
4806436195	2021-07-04	2021-07-04	2021-10-02	ssahub.sans.org	ssahub.sans.org	C=US, O=Let's Encrypt, CN=R3
4800438536	2021-07-02	2021-07-02	2021-09-30	nwt7-999.devnetwars.sans.org	nwt7-999.devnetwars.sans.org	C=US, O=Let's Encrypt, CN=R3
4800438103	2021-07-02	2021-07-02	2021-09-30	nwt7-999.devnetwars.sans.org	nwt7-999.devnetwars.sans.org	C=US, O=Let's Encrypt, CN=R3
4799222462	2021-07-02	2021-07-02	2022-07-31	standby.sans.org	standby.sans.org	C=US, O=Amazon, OU=Server CA 1B, CN=Amazon
4799412492	2021-07-02	2021-07-02	2021-09-30	nwt7-999.devnetwars.sans.org	nwt7-999.devnetwars.sans.org	C=US, O=Let's Encrypt, CN=R3
4799412093	2021-07-02	2021-07-02	2021-09-30	nwt7-999.devnetwars.sans.org	nwt7-999.devnetwars.sans.org	C=US, O=Let's Encrypt, CN=R3
4795134389	2021-07-01	2021-07-01	2021-09-29	nwt7-9999.devnetwars.sans.org	nwt7-9999.devnetwars.sans.org	C=US, O=Let's Encrypt, CN=R3
4795122723	2021-07-01	2021-07-01	2021-09-29	nwt7-9999.devnetwars.sans.org	nwt7-9999.devnetwars.sans.org	C=US, O=Let's Encrypt, CN=R3
4760404812	2021-06-25	2021-06-25	2021-09-23	nwt7-607.devnetwars.sans.org	nwt7-607.devnetwars.sans.org	C=US, O=Let's Encrypt, CN=R3
4760035653	2021-06-25	2021-06-25	2021-09-23	nwt7-607.devnetwars.sans.org	nwt7-607.devnetwars.sans.org	C=US, O=Let's Encrypt, CN=R3
4756280656	2021-06-24	2021-06-24	2021-09-22	nwt7-999.devnetwars.sans.org	nwt7-999.devnetwars.sans.org	C=US, O=Let's Encrypt, CN=R3
4756280816	2021-06-24	2021-06-24	2021-09-22	nwt7-999.devnetwars.sans.org	nwt7-999.devnetwars.sans.org	C=US, O=Let's Encrypt, CN=R3
4755807245	2021-06-24	2021-06-24	2021-09-22	nwt7-646.netwars.sans.org	nwt7-646.netwars.sans.org	C=US, O=Let's Encrypt, CN=R3
4755807397	2021-06-24	2021-06-24	2021-09-22	nwt7-646.netwars.sans.org	nwt7-646.netwars.sans.org	C=US, O=Let's Encrypt, CN=R3
4753485314	2021-06-24	2021-06-24	2021-09-22	apply.immersionacademy.sans.org	apply.immersionacademy.sans.org	C=US, O=Let's Encrypt, CN=R3
4753478461	2021-06-24	2021-06-24	2021-09-22	apply.immersionacademy.sans.org	apply.immersionacademy.sans.org	C=US, O=Let's Encrypt, CN=R3
4741147882	2021-06-21	2021-06-21	2021-09-19	nwt7-777.devnetwars.sans.org	nwt7-777.devnetwars.sans.org	C=US, O=Let's Encrypt, CN=R3
4740154568	2021-06-21	2021-06-21	2021-09-19	nwt7-777.devnetwars.sans.org	nwt7-777.devnetwars.sans.org	C=US, O=Let's Encrypt, CN=R3
4741158360	2021-06-21	2021-06-21	2021-09-19	nwt7-607.devnetwars.sans.org	nwt7-607.devnetwars.sans.org	C=US, O=Let's Encrypt, CN=R3
4739162818	2021-06-21	2021-06-21	2021-09-19	nwt7-607.devnetwars.sans.org	nwt7-607.devnetwars.sans.org	C=US, O=Let's Encrypt, CN=R3
4737422383	2021-06-21	2021-06-21	2022-07-20	api.labs.sans.org	api.labs.sans.org	C=US, O=Amazon, OU=Server CA 1B, CN=Amazon
4738130882	2021-06-21	2021-06-21	2021-09-19	ciso-network.sans.org	ciso-network.sans.org	C=US, O=Let's Encrypt, CN=R3
4735029557	2021-06-21	2021-06-21	2021-09-19	ciso-network.sans.org	ciso-network.sans.org	C=US, O=Let's Encrypt, CN=R3
4729205844	2021-06-18	2021-06-18	2021-09-16	nwt7-777.devnetwars.sans.org	nwt7-777.devnetwars.sans.org	C=US, O=Let's Encrypt, CN=R3
4721672844	2021-06-18	2021-06-18	2021-09-16	nwt7-777.devnetwars.sans.org	nwt7-777.devnetwars.sans.org	C=US, O=Let's Encrypt, CN=R3
4728038010	2021-06-18	2021-06-18	2021-09-16	nwt7-607.devnetwars.sans.org	nwt7-607.devnetwars.sans.org	C=US, O=Let's Encrypt, CN=R3
4721319879	2021-06-18	2021-06-18	2021-09-16	nwt7-607.devnetwars.sans.org	nwt7-607.devnetwars.sans.org	C=US, O=Let's Encrypt, CN=R3
4719749487	2021-06-17	2021-06-17	2022-07-16	*.netwars.sans.org	*.netwars.sans.org	C=US, O=Amazon, OU=Server CA 1B, CN=Amazon
4722633435	2021-06-17	2021-06-17	2021-09-15	nwt7-644.netwars.sans.org	nwt7-644.netwars.sans.org	C=US, O=Let's Encrypt, CN=R3
4719014783	2021-06-17	2021-06-17	2021-09-15	nwt7-644.netwars.sans.org	nwt7-644.netwars.sans.org	C=US, O=Let's Encrypt, CN=R3
4721988366	2021-06-17	2021-06-17	2021-09-15	nwt7-777.devnetwars.sans.org	nwt7-777.devnetwars.sans.org	C=US, O=Let's Encrypt, CN=R3
4720680283	2021-06-17	2021-06-17	2021-09-15	nwt7-777.devnetwars.sans.org	nwt7-777.devnetwars.sans.org	C=US, O=Let's Encrypt, CN=R3
4721363598	2021-06-17	2021-06-17	2021-09-15	nwt7-607.devnetwars.sans.org	nwt7-607.devnetwars.sans.org	C=US, O=Let's Encrypt, CN=R3
4720660266	2021-06-17	2021-06-17	2021-09-15	nwt7-607.devnetwars.sans.org	nwt7-607.devnetwars.sans.org	C=US, O=Let's Encrypt, CN=R3
4712310450	2021-06-16	2021-06-16	2021-09-14	nwt7-607.devnetwars.sans.org	nwt7-607.devnetwars.sans.org	C=US, O=Let's Encrypt, CN=R3
4712311624	2021-06-16	2021-06-16	2021-09-14	nwt7-607.devnetwars.sans.org	nwt7-607.devnetwars.sans.org	C=US, O=Let's Encrypt, CN=R3
4708339264	2021-06-15	2021-06-15	2021-09-13	nwt7-609.devnetwars.sans.org	nwt7-609.devnetwars.sans.org	C=US, O=Let's Encrypt, CN=R3
4708339725	2021-06-15	2021-06-15	2021-09-13	nwt7-609.devnetwars.sans.org	nwt7-609.devnetwars.sans.org	C=US, O=Let's Encrypt, CN=R3
4708317430	2021-06-15	2021-06-15	2022-06-15	ep.sans.org	ep.sans.org	C=GB, ST=Greater Manchester, L=Salford, O=Sectigo Limited, CN=Sectigo RSA Domain Validation Secure Server CA
4708317417	2021-06-15	2021-06-15	2022-06-15	ep.sans.org	www.ep.sans.org	C=GB, ST=Greater Manchester, L=Salford, O=Sectigo Limited, CN=Sectigo RSA Domain Validation Secure Server CA
4708293973	2021-06-15	2021-06-15	2022-06-15	ep.sans.org	www.ep.sans.org	C=GB, ST=Greater Manchester, L=Salford, O=Sectigo Limited, CN=Sectigo RSA Domain Validation Secure Server CA

2. Clicking a certificate result reveals highly detailed information regarding the digital certificate, as the following image shows:

crt.sh
Certificate Search

Criteria
ID = '4824391605'

crt.sh ID	4824391605																																				
Summary	Leaf certificate																																				
Certificate Transparency	Log entries for this certificate: <table style="width: 100%; border-collapse: collapse; margin-top: 5px;"> <thead> <tr> <th style="text-align: left;">Timestamp</th> <th style="text-align: left;">Entry #</th> <th style="text-align: left;">Log Operator</th> <th style="text-align: left;">Log URL</th> </tr> </thead> <tbody> <tr> <td>2021-07-07 07:42:28 UTC</td> <td>1010801277</td> <td>Google</td> <td>https://ct.googleapis.com/logs/argon2021</td> </tr> <tr> <td>2021-07-07 07:42:28 UTC</td> <td>1085748688</td> <td>Google</td> <td>https://ct.googleapis.com/logs/xenon2021</td> </tr> </tbody> </table>	Timestamp	Entry #	Log Operator	Log URL	2021-07-07 07:42:28 UTC	1010801277	Google	https://ct.googleapis.com/logs/argon2021	2021-07-07 07:42:28 UTC	1085748688	Google	https://ct.googleapis.com/logs/xenon2021																								
Timestamp	Entry #	Log Operator	Log URL																																		
2021-07-07 07:42:28 UTC	1010801277	Google	https://ct.googleapis.com/logs/argon2021																																		
2021-07-07 07:42:28 UTC	1085748688	Google	https://ct.googleapis.com/logs/xenon2021																																		
Revocation	<table border="1" style="width: 100%; border-collapse: collapse;"> <thead> <tr> <th>Mechanism</th> <th>Provider</th> <th>Status</th> <th>Revocation Date</th> <th>Last Observed in CRL</th> <th>Last Checked (Error)</th> </tr> </thead> <tbody> <tr> <td>OCSP</td> <td>The CA</td> <td>Check</td> <td>?</td> <td>n/a</td> <td>?</td> </tr> <tr> <td>CRL</td> <td>The CA</td> <td>Unknown</td> <td>n/a</td> <td>n/a</td> <td></td> </tr> <tr> <td>CRLSet/Blocklist</td> <td>Google</td> <td>Not Revoked</td> <td>n/a</td> <td>n/a</td> <td>n/a</td> </tr> <tr> <td>disallowedcert.stl</td> <td>Microsoft</td> <td>Not Revoked</td> <td>n/a</td> <td>n/a</td> <td>n/a</td> </tr> <tr> <td>OneCRL</td> <td>Mozilla</td> <td>Not Revoked</td> <td>n/a</td> <td>n/a</td> <td>n/a</td> </tr> </tbody> </table>	Mechanism	Provider	Status	Revocation Date	Last Observed in CRL	Last Checked (Error)	OCSP	The CA	Check	?	n/a	?	CRL	The CA	Unknown	n/a	n/a		CRLSet/Blocklist	Google	Not Revoked	n/a	n/a	n/a	disallowedcert.stl	Microsoft	Not Revoked	n/a	n/a	n/a	OneCRL	Mozilla	Not Revoked	n/a	n/a	n/a
Mechanism	Provider	Status	Revocation Date	Last Observed in CRL	Last Checked (Error)																																
OCSP	The CA	Check	?	n/a	?																																
CRL	The CA	Unknown	n/a	n/a																																	
CRLSet/Blocklist	Google	Not Revoked	n/a	n/a	n/a																																
disallowedcert.stl	Microsoft	Not Revoked	n/a	n/a	n/a																																
OneCRL	Mozilla	Not Revoked	n/a	n/a	n/a																																
Certificate Fingerprints	SHA-256 AAA06503E6D20F63B70B1EA87A83E86CA8AF767BF0CA7E31D643A134FE8DB7F4 SHA-1 310C56A34673FD404F5DDDD0F815751E8B4E15A																																				
Certificate ASN.1 Graph pv Hide metadata Run cablint Run x509lint Run zlint Download Certificate: PEM	Certificate: Data: Version: 3 (0x2) Serial Number: 03:fd:f3:31:60:03:06:15:85:cd:2b:16:38:41:9b:b2:5d:7c Signature Algorithm: sha256WithRSAEncryption Issuer: (CA ID: 183267) commonName = R3 organizationName = Let's Encrypt countryName = US Validity Not Before: Jul 7 06:42:27 2021 GMT Not After : Oct 5 06:42:26 2021 GMT Subject: ...																																				

- This information is very useful for finding subdomains of targets. In this example, we can see that the certificate was issued on 07-07-2021, which means the domain is likely still active. An expired certificate would suggest the domain is inactive.

11. Shodan

During reconnaissance and OSINT, we use several tools and techniques to gather information about the target. The next reconnaissance tool that we'll learn is **Shodan.io**.

- **Shodan.io** is a website that conducts port scanning across the entire internet and catalogs the results for quick searching.
- This site is useful, because it saves us the time we would spend conducting a port scan. Not having to conduct this scan also allows us to keep our originating IP address hidden.
- Shodan is just one of several websites that conduct port scanning. These fall under the MITRE technique **Search Open Technical Databases: Scan Databases, ID T1596.005**.

- <https://attack.mitre.org/techniques/T1596/005/>.

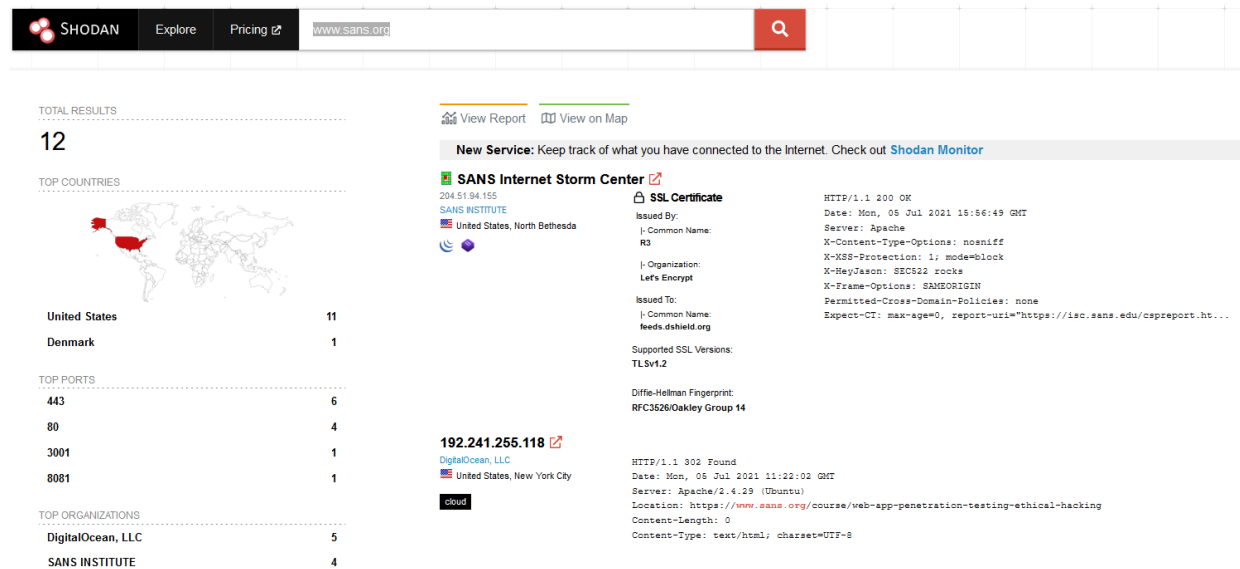
Shodan Demonstration

Note: You will need to create a free Shodan account to conduct this demonstration.

:warning: Shodan.io limits the number of searches that can be done with the free account. This limit resets daily, but you are encouraged to watch the demo and save searches for the activity.

1. Navigate to Shodan.io and log in with the Shodan account that you created before class.

- In the search bar, type "www.sans.org".
- This search will return several findings, including SSL certs and IP addresses that have a DNS entry with "SANS" in the name, as the following image shows:



2. Click the second result with the IP address 192.241.255.118.

- This page contains a lot of useful information. Note the open ports of the IP address and the DNS name in the "Location" field of one of the ports, as the following image shows:

General Information

Country	United States
City	New York City
Organization	DigitalOcean, LLC
ISP	DigitalOcean, LLC
ASN	AS14061

Vulnerabilities

Note: the device may not be impacted by all of these issues. The vulnerabilities are implied based on the software and version.

CVE-2019-0220 A vulnerability was found in Apache HTTP Server 2.4.0 to 2.4.38. When the path component of a request URL contains multiple consecutive slashes ('/'), directives such as LocationMatch and RewriteRule must account for duplicates in regular expressions while other aspects of the servers processing will implicitly collapse them.

CVE-2019-0197 A vulnerability was found in Apache HTTP Server 2.4.34 to 2.4.38. When HTTP/2 was enabled for a

Open Ports

80 / TCP

Apache httpd 2.4.29

HTTP/1.1 302 Found
Date: Mon, 05 Jul 2021 11:22:02 GMT
Server: Apache/2.4.29 (Ubuntu)
Location: https://www.sans.org/course/web-app-penetration-testing-ethical-hacking
Content-Length: 0
Content-Type: text/html; charset=UTF-8

443 / TCP

Apache httpd 2.4.29

HTTP/1.1 302 Found
Date: Sat, 26 Jun 2021 06:50:12 GMT
Server: Apache/2.4.29 (Ubuntu)
Location: https://www.sans.org/course/web-app-penetration-testing-ethical-hacking
Content-Length: 0
Content-Type: text/html; charset=UTF-8

3. **CVE** stands for **common vulnerabilities and exposures**. Any vulnerability that is found for any OS, application, API, etc. is assigned a CVE number.

- Shodan automatically scans for CVEs and will suggest any potential CVEs to which the application is vulnerable.
- In this example, we can see that CVE-2019-0220 may be applicable to this site, suggesting a denial-of-service attack is possible. Just because a CVE is listed here, doesn't mean that the application is confirmed to be vulnerable. Shodan, like other vulnerability scanners, make assumptions based on versions of services.

Summary

- **Certificate transparency** is a reconnaissance tactic wherein a penetration tester can gather information from certificate issuers, which publish logs of the SSL/TLS certificates that they issue to organizations.
 - Attackers can exploit certificate transparency and used it to search for subdomains.
- **Shodan.io** is a reconnaissance website that conducts port scanning across the entire internet and catalogs the results for quick searching.

In the next activity, we will continue to play the role of a penetration tester and conduct a reconnaissance tactic by using Shodan.io to look at previous scans for MegaCorpOne.

12. Activity: Shodan.io

- [Activity File: Shodan.io](#)
-

13. Activity Review: Shodan.io

14. Recon-ng

We have taken the following steps so far:

- First, we undertook the **planning** part of the **planning and reconnaissance** phase by determining whether potential assessments were legal or illegal and what type of pen tests were required.
- Then, we began passive reconnaissance by using **Google hacking** to look for publicly available information.
- After that, we used **Shodan.io** to view previously completed port scans on several targets.

We'll continue our reconnaissance efforts with another tool called **Recon-ng**.

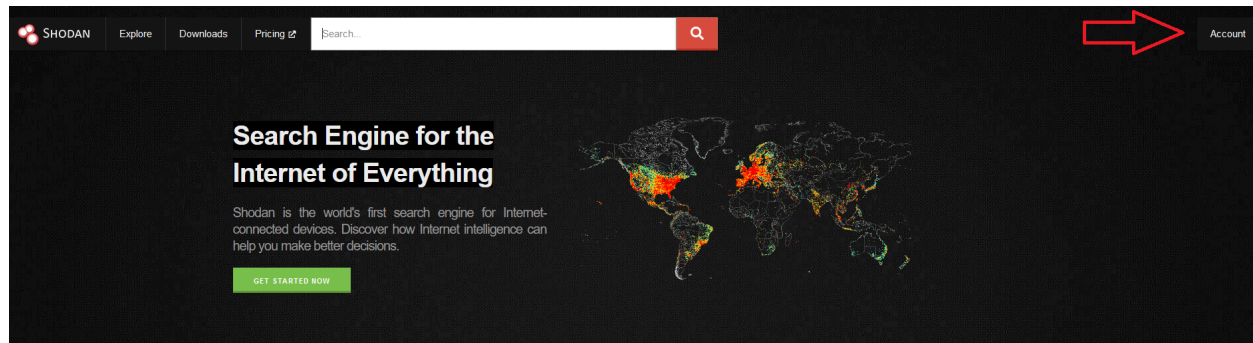
- **Recon-ng** is a web reconnaissance framework written in Python.
- Recon-ng provides a powerful, open-source, web-based framework for conducting reconnaissance quickly and thoroughly. It includes the following features:
 - Independent modules
 - Database interaction
 - Built-in convenience functions
 - Interactive help
 - Command completion

There are many scripts and programs that can assist with integrating OSINT tools into Recon-ng.

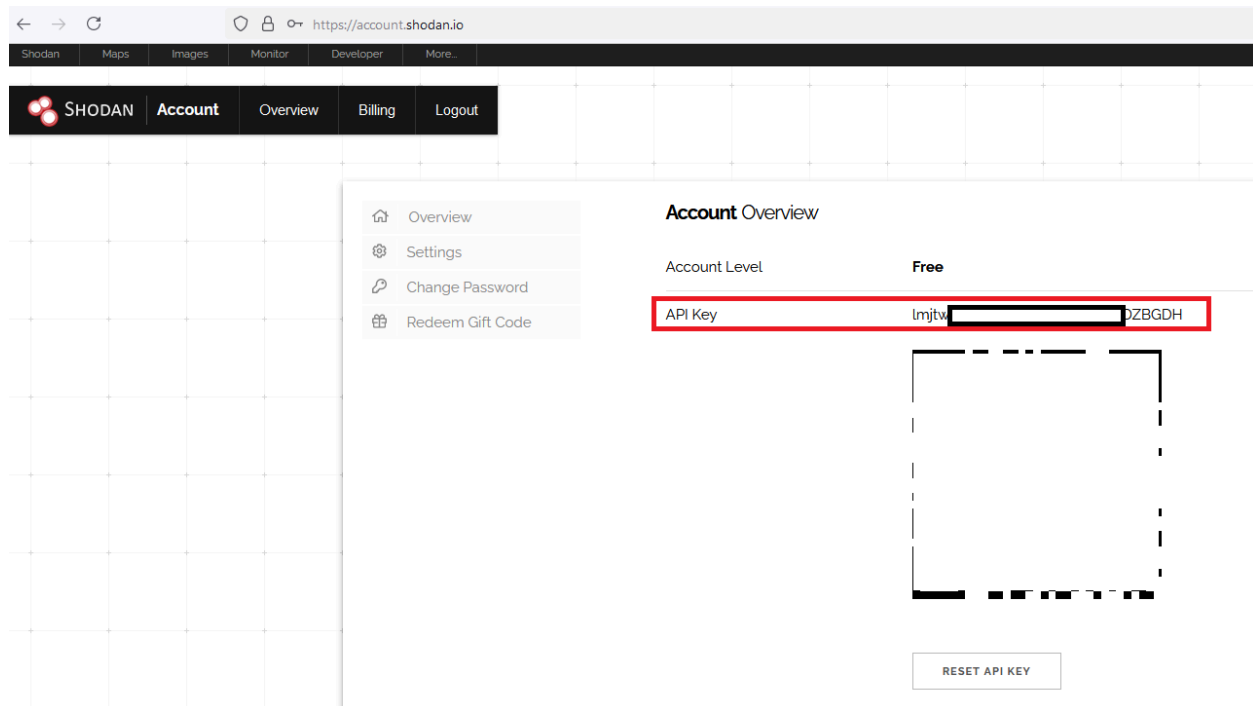
- Recon-ng is a framework that ingests a lot of popular OSINT modules, allowing the results of multiple tools to be combined into a single report.
- Recon-ng also went through a major update recently. The following link details changes from version 4.x to 5.x and a set of new, handy commands that comes with the newer 5.x version. [Read about the changes](#).

Recon-ng Demonstration

In this demonstration, we will use Recon-ng in our Kali VM.



- Copy the API key to your clipboard, as the following image shows. You'll use it again in Step 4.



3. In Recon-ng, run `modules search` to view all of the currently installed modules.

- For this activity, we'll use the following two modules:
 - `recon/domains-hosts/hackertarget`
 - `recon/hosts-ports/shodan_ip`

- ```
[root@kali:~]# recon-ng
[!] 'shodan_api' key not set. shodan_ip module will likely fail at runtime. See 'keys add'.
[*] Version check disabled.
```
- Sponsored by...
- BLACK HILLS  
www.blackhillinfosec.com
- PRACTISEC  
www.practisec.com
- ```
[recon-ng v5.1.1, Tim Tomes (@lanmaster53)]

[2] Recon modules
[1] Reporting modules

[recon-ng][default] > modules search

Recon
-----
recon/domains-hosts/hackertarget
recon/hosts-ports/shodan_ip

Reporting
-----
reporting/html

[recon-ng][default] >
```

- © 2024 edX Boot Camps LLC. Confidential and Proprietary. All Rights Reserved.

- Individual IPs
- A domain name
- For this example, we'll set the domain name sans.org as our **SOURCE** option.

```
[recon-ng][default][shodan_ip] > info
```

Name: Shodan IP Enumerator
 Author: Tim Tomes (@lanmaster53) and Matt Puckett (@t3lc0)
 Version: 1.0
 Keys: shodan_api

Description:
 Harvests port information from the Shodan API by using the 'ip' search operator. Updates the 'ports' table with the results.

Options:

Name	Current Value	Required	Description
LIMIT	1	yes	limit number of api requests per input source (0 = unlimited)
SOURCE	default	yes	source of input (see 'info' for details)

Source Options:
 default SELECT DISTINCT ip_address FROM hosts WHERE ip_address IS NOT NULL
 <string> string representing a single input
 <path> path to a file containing a list of inputs
 query <sql> database query returning one column of inputs

- Set the **SOURCE** to sans.org by typing **options set SOURCE sans.org**, as the following image shows:

```
[recon-ng][default][shodan_ip] > options set SOURCE sans.org
```

SOURCE => sans.org

```
[recon-ng][default][shodan_ip] > info
```

Name: Shodan IP Enumerator
 Author: Tim Tomes (@lanmaster53) and Matt Puckett (@t3lc0)
 Version: 1.0
 Keys: shodan_api

Description:
 Harvests port information from the Shodan API by using the 'ip' search operator. Updates the 'ports' table with the results.

Options:

Name	Current Value	Required	Description
LIMIT	1	yes	limit number of api requests per input source (0 = unlimited)
SOURCE	sans.org	yes	source of input (see 'info' for details)

Source Options:
 default SELECT DISTINCT ip_address FROM hosts WHERE ip_address IS NOT NULL
 <string> string representing a single input
 <path> path to a file containing a list of inputs
 query <sql> database query returning one column of inputs

```
[recon-ng][default][shodan_ip] >
```

- Using Shodan with a pro account allows you to query open ports on your discovered hosts without having to send packets to target systems.

7. Now, we'll use an additional module called **HackerTarget**.

- HackerTarget will use Shodan to query all of the hosts that belong to sans.org.

- **Note:** Although HackerTarget can find hosts by itself, combining modules produces better scan results by discovering additional hosts that would otherwise be missed.
8. Next, we'll load the `recon/domains-hosts/hackertarget` module and change its `SOURCE` to that of the target.

- Type `modules load recon/domains-hosts/hackertarget`.
- This will load the `recon/domains-hosts/hackertarget` scanner module.
- Now that the module is loaded, type `info` to check the `SOURCE` setting, as the following image shows:

```
[recon-ng][default][shodan_ip] > modules load recon/domains-hosts/hackertarget
[recon-ng][default][hackertarget] > info

Name: HackerTarget Lookup
Author: Michael Henriksen (@michenriksen)
Version: 1.0

Description:
  Uses the HackerTarget.com API to find host names. Updates the 'hosts' table with the results.

Options:
  Name      Current Value  Required  Description
  -----
  SOURCE    default        yes       source of input (see 'info' for details)

Source Options:
  default      SELECT DISTINCT domain FROM domains WHERE domain IS NOT NULL
  <string>     string representing a single input
  <path>       path to a file containing a list of inputs
  query <sql>  database query returning one column of inputs

[recon-ng][default][hackertarget] > 
```

- Set the `SOURCE` to `sans.org` by typing `options set SOURCE sans.org`, as the following image shows:

```
[recon-ng][default][hackertarget] > options set SOURCE sans.org
SOURCE => sans.org
[recon-ng][default][hackertarget] > info

Name: HackerTarget Lookup
Author: Michael Henriksen (@michenriksen)
Version: 1.0

Description:
  Uses the HackerTarget.com API to find host names. Updates the 'hosts' table with the results.

Options:
  Name      Current Value  Required  Description
  -----
  SOURCE    sans.org       yes       source of input (see 'info' for details)

Source Options:
  default      SELECT DISTINCT domain FROM domains WHERE domain IS NOT NULL
  <string>     string representing a single input
  <path>       path to a file containing a list of inputs
  query <sql>  database query returning one column of inputs

[recon-ng][default][hackertarget] > 
```

- The HackerTarget and Shodan modules serve two distinct purposes:

- The HackerTarget module uses the **SOURCE** option to display scan results verbosely.
- The Shodan module uses the **SOURCE** option to specify which target Recon-ng will scan.

9. From within the **hackertarget** module, type **run**, as the following image shows:

```
root@kali: ~  
[recon-ng][default][hackertarget] > run  
-----  
SANS.ORG  
-----  
[*] Country: None  
[*] Host: sans.org  
[*] Ip Address: 45.60.103.34  
[*] Latitude: None  
[*] Longitude: None  
[*] Notes: None  
[*] Region: None  
-----  
[*] Country: None  
[*] Host: gitlab.tbt570.sans.org  
[*] Ip Address: 35.226.225.220  
[*] Latitude: None  
[*] Longitude: None  
[*] Notes: None  
[*] Region: None  
-----  
[*] Country: None  
[*] Host: rtir.tbt570.sans.org  
[*] Ip Address: 35.226.225.220  
[*] Latitude: None  
[*] Longitude: None  
[*] Notes: None  
[*] Region: None  
-----  
[*] Country: None  
[*] Host: files.tbt570.sans.org  
[*] Ip Address: 35.226.225.220  
[*] Latitude: None  
[*] Longitude: None  
[*] Notes: None  
[*] Region: None
```

- Recon-ng will query Shodan for sans.org.
- The results will automatically display verbosely in the terminal window.

Summary

- **Recon-ng** is a tool written in Python and used primarily for information gathering by ethical hackers, such as penetration testers.
- Recon-ng comes preloaded with numerous modules that use online search engines, plugins, and APIs, which work together to gather information against a target.
- Network defenders use information obtained from Recon-ng to formulate mitigation strategies that help defend their networks.

In the final activity, we will continue to play the role of a penetration tester and will conduct another reconnaissance tactic by using Recon-ng to gather additional data on MegaCorpOne.

15. Activity: Recon-ng

- [Activity File: Recon-ng](#)

Congratulations on completing the first phase of a penetration testing engagement: Planning and reconnaissance!

In the next class, we will learn how to conduct the second phase, scanning.

16. Activity Review: Recon-ng